Universiteit van Amsterdam
Amsterdam Business School

Fundamentals of IT-auditing

IT-auditing from a governance perspective

Prof. dr. Edo Roos Lindgreen

Agenda

What is IT-auditing? **Why** do we do it? **How** is it done?

1. Personal introduction
2. Corporate governance
3. Audit as a source of information
4. What is keeping the board awake at night?
5. Introduction to IT-auditing
6. Example cases
7. Phases in the audit
8. Hot topics in IT-auditing

Personal introduction

- Computer Science UvA (1989)
- PhD Computer Security, Delft University of Technology (1996)
- KPMG (partner, 1996-2017)
- UvA (professor, 1998-present)

- Cybersecurity journey: Corporate Information Security

- Lesson learned: **it all starts and ends with governance**.

- Now, let's talk about governance.

Governance: how we run our companies

What is the purpose of a company?

And what are the preconditions (if any)?

Governance: how we run our companies

What is the purpose of a company?

- Generate profit? Enrich the founder, the owners, the shareholders?
- Provide work and income to its employees?
- Create great products for consumers?
- Add value to society?

And what are the preconditions (if any)?

- Avoid excessive damage to society?
- Obey the law in general?
- Display moral and ethical behaviour?
- Environment: no pollution, no toxic ingredients, no emissions, etc?
- Social: no child labor, no forced labor, no dangerous work environment?
- Governance: no fraud, no tax evasion, no conflicts of interest?

Create sustainable, lasting value for all stakeholders

Corporate governance

Corporate governance: the way we manage the complex relationship between the shareholders, who own the company; the executive board, who are responsible for the company's strategy and manage it on a day-to-day basis; and the non-executive or supervisory board. Principles and guidelines are laid out in various Corporate Governance Codes (see Canvas).

Continuity
Sustainable long-term value creation

Trust
Integrity
Transparency

Supervisory board

STAKEHOLDERS

Comply or explain

Executive board

Shareholders

In addition to these three entities, there are important entities inside the company: Exco, CIO, CISO, Internal Audit, Risk Management. And there are also important entities outside the company: customers, suppliers; supervisory authorities; and the external auditor. We'll talk more about those later.

Division of responsibilities

- In corporate governance, a proper division of responsibilities is key.
- Executive board: strategy + risk management.
- Supervisory board: supervision, employment, advise, ambassador. Very Important!
- One-tier, Anglosaxon: executive and non-executive board members, in the same meeting.
- Two-tier, Rhineland: supervisory board and executive board, separate meetings, 6-8x per annum.

Where does the supervisory board get its information?

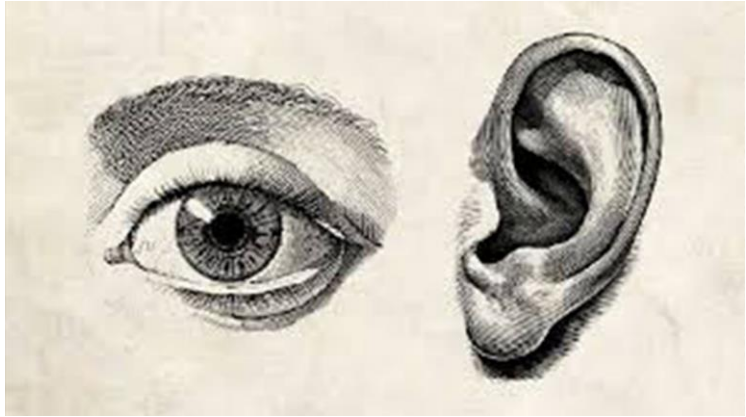
How can the supervisory board fulfill their role? Which sources of **information** do they have?

- **Board reports**: may be insufficient – board gives incomplete information, intentionally or non-intentionally.
- **Own observation**: often too limited.

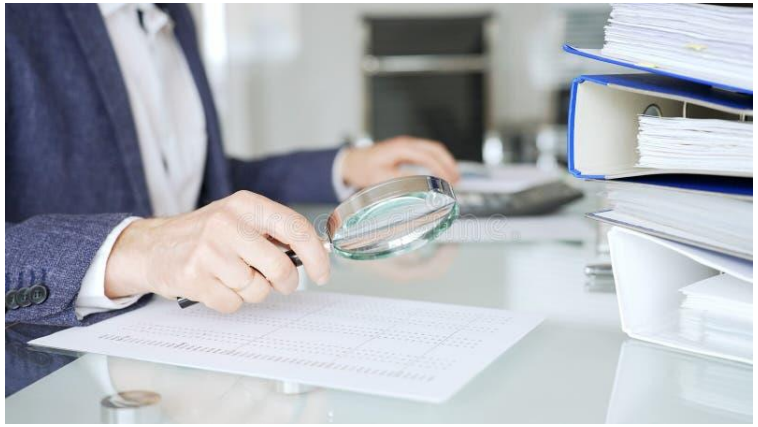
So how are we going to solve this? Introducing ***auditing*** to provide an independent source of information on things that are relevant to the supervisory board.

Auditing is so important to the supervisory board that it has a special committee: the **audit committee**. Also, audit has a prominent presence in corporate governance codes.

So let's take a look at auditing.



Introduction to auditing



- From Latin audire: to hear
- Indepent assessment or evaluation.
- **Internal audit** vs **external (financial) audit**
- Provide **reasonable** or **limited assurance**, find **deficiencies**, give **recommendations**.
- Sometimes: special investigations.
- **Financial audit**: provide assurance on reliability of financial reports
  - Babylonia, Egypt, Ancient Greece, Middle Ages England and Italy
  - From 1840: industrial revolution, corporations, investors: financial auditor
- Around a century ago, large multinational companies started **internal audit**
- Auditing is a very large profession: financial audit (2 mln professionals). Internal audit: 300.000.
- In general, auditors are specialised in: finance, accounting, business. The career path is usually via finance, accounting, etc.
- Now, let’s take a look at what’s keeping the board awake…

Digital is keeping the board awake at night

IIA Risk in Focus 2026 (see Canvas)

1. **Cybersecurity**
2. **Digital Disruption**
3. Geopolitical instability
4. …

Key questions the supervisory board might have:

- Is our strategy future-proof?
- Are our investments aligned with our strategy?
- Are we in control on IT investments (capex) and operational costs (opex)?
- Are we compliant with relevant regulation?
- Are we secure? Are we protected against ransomware attacks?
- Are we protected against espionage? Fraud?

Question: do internal and financial auditors have the digital expertise necessary to answer these questions?

The emergence of the IT-auditor

- 50 years ago, it became clear that “normal” auditors did not have the knowledge and expertise to answer technology-related questions
- Emergence of a new profession: the EDP-auditor, now called the IT-auditor
- IT-audit: the professional and independent evaluation of risks associated with the use of information technology and the effectiveness of controls to mitigate these risks.
- Started in financial audit, soon spread to internal audit
- Professional education: e.g. Executive MSc of Auditing Studies, Digital Auditing
- Professional qualifications: CISA, RE; professional organizations: ISACA (185.000 members), NOREA (1800)
- Professional standards: ISACA IT Audit Framework, IIA Global Internal Audit Standards, COBIT
- https://abs.uva.nl/content/executive-master/auditing-studies-digital-auditing/auditing-studies-digital-auditing
- IT-audit as a springboard for a career elsewhere: you can find them in high positions, as board members, entrepreneurs, investors

Example 1 – Mega project

- Large company
- 400 mln key project
- A platform for everything
- External accountant requested IT-audit
  - Valuation
  - Going concern
- Outcome: findings re viability of project
- Discussed with management

Example 2 – Cybersecurity policy

- Multinational trading company
- Global cybersecurity policy defined, approved and implemented
- Management requested IT-audit
  - Is policy implemented and tested at all operating companies?
- Outcome: security policy only partially implemented
- Findings discussed with management
- Supervision intensified

Example 3 – Mission-critical system

- Dutch railway provider
- Procured new systems for traffic control
- Management requested IT-audit
  - Deployment risks
  - Vulnerabilities
- Findings re continuity and cybersecurity
- Discussed with management
- Deployment delayed

Example 4 – European DC

- Multinational Japanese electronics company
- European distribution center
- Management requested IT-audit
  - Business continuity
- Findings: IBM AS/400 system Single Point of Failure
- Discussed with management
- Impact: investment in modern redundant IT infrastructure

Key drivers in the evolution of IT-auditing

- *Economic transformations and financial crises*
- *Technological advancements*
- *Regulatory reforms and compliance requirements*
- *Professional associations and standardization*
- *Globalization and technological complexity*
- *Changing business environment*

van den Heuvel E (2025) Evolution of IT auditing in a nutshell – journey towards a dynamic landscape. Maandblad voor Accountancy en Bedrijfseconomie 99(2): 73-83. https://doi.org/10.5117/mab.99.140994

Phases in an IT-audit engagement

1. Planning and Scoping: Defines the audit's purpose, objectives, and scope. It involves understanding the business environment, critical systems, and defining the roadmap.

2. Fieldwork and Control Testing: The core phase where auditors gather evidence through interviews, observation, and inspecting documentation. Controls (e.g., access, change management) are tested to ensure they are designed and operating effectively.

3. Reporting and Analysis: Analyzes findings, evaluates their severity (e.g., high, medium, low), and presents a report to management with actionable recommendations and, if necessary, management responses.

4. Follow-Up: Ensures that the agreed-upon remediation actions or improvements to address audit findings are implemented by management.

Phase 1 – Risk assessment, planning and scoping

- Understanding the business
- Risk assessment
- Scoping the engagement: scope and depth
- Interfaces with other processes and IT systems
- Limited or reasonable assurance
- Necessary conditions
- Audit approach and standards
- Data required, respondents, stakeholders
- Time frame
- Communication plan
- *Agree on engagement with stakeholders*

Phase 2 - Fieldwork and controls testing

- **Fieldwork** is a combination of:
  - **Data analysis**: authorizations, log data, process mining
  - **Reading reports**: management reports, audit reports
  - **Interviews** with stakeholders: CIO, CISO, developers, users
  - **Observation**: site visits
  - **Probing and testing**: red teaming, pentesting,

- Building the **audit file**: evidence

Phase 3 - Reporting and analysis

- Interview minutes
- Draft report
- “Audi alteram partem”
- Management response
- Final report
- Presentation to stakeholders

Figure 1—IT Audit Report Components

Report Component	Source
An appropriate and distinctive title	ITAF
Identification of the recipients to whom the report is directed	ITAF
Identification of the responsible party	ITAF
Table of contents	*IS Audit Reporting*
Introduction	*IS Audit Reporting*
Description of the scope of the audit engagement	ITAF
A statement identifying the source of management's representation about the effectiveness of control procedures	ITAF
A statement that professionals have conducted the audit engagement to express an opinion on the effectiveness of control procedures	ITAF
Identification of the purpose (objectives) of the audit	ITAF
Description of the criteria or disclosure of the source of the criteria	ITAF
A statement that the audit engagement has been conducted in accordance with ISACA IS audit and assurance standards or other applicable professional standards	ITAF
Further explanatory details about the variables that affect the assurance provided	ITAF
Findings, conclusions and recommendations for corrective action including management's response	ITAF
Auditor reply	*IS Audit Reporting*
A paragraph stating that because of the inherent limitations of any internal control, misstatements due to errors or fraud may occur and go undetected	ITAF
A summary of the (audit) work performed	ITAF
An expression of opinion about whether, in all material respects, the design and/or operation of control procedures in relation to the area of activity were effective	ITAF
Executive summary	*IS Audit Reporting*
Where appropriate, references to any other separate reports that should be considered	ITAF
Date of issuance of the audit engagement report. In most instances, the date of the report is based upon the issue date.	ITAF
Names of individuals or entity responsible for the report	ITAF
Appendix	*IS Audit Reporting*

Phase 4 - Followup

Management implements recommendations and takes measures

IT-auditor monitors process and assesses effectiveness of measures

Hot topics in IT-auditing

- **Cybersecurity** – are we in control? Are we protected against threats? If an incident occurs, can we detect it and respond timely? More on this next week
- **IT Continuity** – do we have measures in place to ensure the continuity of our operations? Not only against hackers, but also against other disruptions? Anecdotes: vacuum cleaner in NS station, director operations in data center
- **Innovation** – are we prepared for the uncertain future that awaits us? Are we breakfast for the next generations of AI models that will be unleashed? Or will we be able to be the disruptor?
- **Compliance** – are we compliant with relevant legislation and regulation? General, also IT-specific: DORA, GDPR, NIS2, EU AI Act?
- **AI** – speaking of which: what the heck is going on? Agentic AI, Open Claw, vibe coding? “Cancel ChatGPT”? Mega impact: strategy, operations, risk management? But how can we audit this?

Next week:

Deep dive: cybersecurity auditing, AI auditing

Edo Roos Lindgreen

Guest lecture: post mortem incident analysis

Jeroen van Beek

Evalueer via **https://app.evalytics.nl/#**

zja-176